

KONGALI SECURITY

Professional Security Assessment Report

Target	https://blanchedalmond-gorilla-295483.hostingersite.com
Overall Risk	CRITICAL
Security Score	0/100
Generated	2026-07-23T02:13:26.587610+00:00
Scanner	Kongali Security
Scanner Version	0.2.0

Confidential Security Assessment

1. Executive Summary

This security assessment was generated by Kongali Security to identify security weaknesses and provide actionable remediation guidance. Findings are categorized by severity and enriched with OWASP Top 10, CWE, CVSS, impact, evidence, and remediation information where available.

Metric	Value
Target	https://blanchedalmond-gorilla-295483.hostingersite.com
Overall Risk	CRITICAL
Security Score	0/100
Total Findings	6
Critical	0
High	4
Medium	2
Low	0

2. Security Findings

1. Missing security header: Content-Security-Policy

Severity	HIGH
Category	HTTP Security Headers
OWASP	{'id': 'A05:2021', 'name': 'Security Misconfiguration'}
CWE	{'id': 'CWE-693', 'name': 'Protection Mechanism Failure'}
CVSS	8.1
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Description	The HTTP response does not include the Content-Security-Policy security header.
Impact	Missing Content-Security-Policy may increase the risk of client-side injection and content execution attacks.
Remediation	Implement a restrictive Content-Security-Policy appropriate for the application.
Evidence	{'header': 'Content-Security-Policy', 'status': 'missing'}

2. Missing security header: Strict-Transport-Security

Severity	HIGH
Category	HTTP Security Headers
OWASP	{'id': 'A05:2021', 'name': 'Security Misconfiguration'}
CWE	{'id': 'CWE-319', 'name': 'Cleartext Transmission of Sensitive Information'}
CVSS	8.1

CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Description	The HTTP response does not include the Strict-Transport-Security security header.
Impact	Without HSTS, users may be exposed to protocol downgrade or insecure HTTP connections.
Remediation	Enable HTTP Strict Transport Security with an appropriate max-age and HTTPS deployment.
Evidence	{'header': 'Strict-Transport-Security', 'status': 'missing'}

3. Missing security header: X-Content-Type-Options

Severity	HIGH
Category	HTTP Security Headers
OWASP	{'id': 'A05:2021', 'name': 'Security Misconfiguration'}
CWE	{'id': 'CWE-693', 'name': 'Protection Mechanism Failure'}
CVSS	8.1
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Description	The HTTP response does not include the X-Content-Type-Options security header.
Impact	Missing X-Content-Type-Options may allow browsers to MIME-sniff responses unexpectedly.
Remediation	Set the X-Content-Type-Options header to nosniff.
Evidence	{'header': 'X-Content-Type-Options', 'status': 'missing'}

4. Missing security header: X-Frame-Options

Severity	HIGH
Category	HTTP Security Headers
OWASP	{'id': 'A05:2021', 'name': 'Security Misconfiguration'}
CWE	{'id': 'CWE-693', 'name': 'Protection Mechanism Failure'}
CVSS	8.1
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Description	The HTTP response does not include the X-Frame-Options security header.
Impact	Missing clickjacking protection may allow malicious sites to frame the application.
Remediation	Set X-Frame-Options to DENY or SAMEORIGIN, or use an appropriate CSP frame-ancestors policy.
Evidence	{'header': 'X-Frame-Options', 'status': 'missing'}

5. Missing security header: Referrer-Policy

Severity	MEDIUM
Category	HTTP Security Headers
OWASP	{'id': 'A05:2021', 'name': 'Security Misconfiguration'}
CWE	{'id': 'CWE-200', 'name': 'Exposure of Sensitive Information to an Unauthorized Actor'}

CVSS	6.4
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Description	The HTTP response does not include the Referrer-Policy security header.
Impact	An overly permissive referrer policy may expose sensitive URL information to external origins.
Remediation	Configure a restrictive Referrer-Policy such as strict-origin-when-cross-origin.
Evidence	{'header': 'Referrer-Policy', 'status': 'missing'}

6. Missing security header: Permissions-Policy

Severity	MEDIUM
Category	HTTP Security Headers
OWASP	{'id': 'A05:2021', 'name': 'Security Misconfiguration'}
CWE	{'id': 'CWE-693', 'name': 'Protection Mechanism Failure'}
CVSS	6.4
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Description	The HTTP response does not include the Permissions-Policy security header.
Impact	Missing Permissions-Policy may allow unnecessary browser capabilities to remain available.
Remediation	Configure Permissions-Policy to explicitly restrict unnecessary browser capabilities.
Evidence	{'header': 'Permissions-Policy', 'status': 'missing'}

3. Assessment Methodology

- HTTP security header analysis
- Security finding classification
- OWASP Top 10 mapping
- CWE classification
- CVSS v3.1 risk scoring
- Evidence collection
- Remediation guidance
- SARIF-compatible security reporting
- Baseline security regression comparison

4. Risk Interpretation

Risk ratings should be interpreted in the context of the application, deployment architecture, exposed attack surface, business impact, and existing compensating controls. CVSS scores provide a standardized technical severity indicator and should not replace organizational risk analysis.

5. Recommendations

Prioritize remediation of Critical and High severity findings. After remediation, rerun Kongali Security and compare the new assessment against the established security baseline. Integrate SARIF output into CI/CD pipelines to detect security regressions before changes are merged.

Generated by Kongali Security